

Informe de implementación

Rediseño del sitio público y panel administrativo
SAMAP — Medicina Prepaga del Sanatorio Adventista de Asunción

Repositorio	WebSamap
Branch	feat/rediseno-web
Commits totales	49
Archivos tocados	280
Líneas añadidas	+26.538
Líneas eliminadas	-4.295
Fecha del informe	29/06/2026

El presente documento detalla, de punta a punta, el trabajo realizado sobre el branch **feat/rediseno-web**: desde la solicitud inicial (montar el entorno local y rediseñar el sitio público) hasta las cuatro fases de mejora del panel administrativo. Cada bloque incluye su objetivo, los commits asociados y el detalle funcional de lo entregado.

Índice

1. Solicitud inicial y contexto del proyecto
2. Bloque A — Infraestructura y arranque
3. Bloque B — Rediseño del sitio público (marketing)
4. Bloque C — Endurecimiento de seguridad inicial
5. Bloque D — UX del panel admin (mejoras tempranas)
6. Bloque E — Beneficios y aliados configurables
7. FASE 1 — Quick wins UX del admin
8. FASE 2 — Productividad en listados
9. FASE 3 — Nuevas funcionalidades
10. FASE 4 — Calidad, seguridad y autonomía
11. QA — Scripts de testing
12. Inventario final y métricas
13. Estado actual del repositorio

1. Solicitud inicial y contexto del proyecto

Punto de partida

El sitio original de SAMAP era una mezcla de template HTML5 médico y un panel PHP legacy con las siguientes carencias:

- Un único usuario administrador con contraseña MD5 hardcoded en la base.
- Sin sistema de búsqueda, papelera, auditoría ni recuperación de contraseña.
- Validación de inputs débil, vulnerabilidades de XSS stored y SQLi en varios endpoints.
- alert() y window.location.href como mecanismo de feedback (113 ocurrencias).
- Sin separación de roles: cualquier sesión podía escribir en cualquier módulo.
- Listados sin paginación, sin búsqueda, sin exportar y sin soft-delete.
- Formularios de contacto y «Trabajá con Nosotros» sin persistir en base.
- Imposible para Marketing operar el CMS sin asistencia técnica.

Pedido del cliente

El cliente entregó un brief (web.pdf) y los manuales de marca (paleta institucional #274767 azul Red Hospitales IASD y #6CA3AB verde mar SAMAP) solicitando:

- Rediseñar el sitio público respetando la identidad visual de la marca.
- Modernizar el panel para que sea operable por personas de Marketing sin conocimientos técnicos.
- Endurecer la seguridad para cumplir con la Ley 6534/20 de protección de datos personales del Paraguay.
- Conservar la arquitectura PHP existente y la base de datos legacy web_samap.

Estrategia de trabajo

El trabajo se organizó en bloques iniciales (infra, rediseño público, seguridad temprana, UX del admin, beneficios) y luego se ejecutaron **cuatro fases** incrementales sobre el panel administrativo. Cada fase siguió el ciclo *Analizar* → *Desarrollar* → *Testear* → *Corregir*, delegando trabajo en agentes especializados cuando la tarea lo justificaba.

2. Bloque A — Infraestructura y arranque

Objetivo

Levantar un entorno reproducible para trabajar contra el código legacy sin depender del servidor de producción. Se construyó un Docker Compose con MySQL 8 + Apache/PHP, seed de la base con el dump original y volúmenes mapeados al working tree para edición en vivo.

Commit

Hash	Descripción
a65e1be	chore(infra): entorno local Docker + fixes para levantar el sitio

3. Bloque B — Rediseño del sitio público (marketing)

Objetivo

Aplicar la identidad visual de SAMAP al sitio público, mejorar UX móvil, incorporar descargas de PDF (Guía Médica, anexo por plan), reforzar SEO y cumplimiento legal, y agregar la sección de Descuentos Exclusivos.

Commits

Hash	Descripción
68b2793	docs: brief de rediseño del sitio público (desde web.pdf)
dbba4ba	feat(marketing): rediseño del sitio público según brief (web.pdf)
b4f8d65	fix(marketing): elimina botones duplicados en header desktop y usa foto limpia en hero
3028ad6	feat(marketing): mejoras móviles, limpieza de home y nuevo aliado gym
3fe8aa3	fix(marketing): mejora UX mobile y sección Descuentos Exclusivos
7bdc11a	feat(marketing): descarga de Guía Médica en PDF + cache-busting de CSS
7c825e1	feat(web): endurece seguridad, SEO, rendimiento y cumplimiento legal
4ab200f	feat(marketing): agrega descarga de anexo PDF por plan y presupuesto

4. Bloque C — Endurecimiento de seguridad inicial

Objetivo

Cerrar las vulnerabilidades críticas detectadas en una primera pasada: credenciales fuera del repo, login con CSRF, queries parametrizadas, validación de uploads por magic bytes y soft-delete con roles.

Commits

Hash	Descripción
4956500	fix(admin): endurece seguridad del panel (credenciales, SQLi, uploads, login)
804c0bd	feat(admin): soft-delete y roles de usuario (#8, #9)
1c5cedc	fix(security): castea IDs a entero en guiamedica para cerrar SQLi (#2)
eaebf27	fix(leads): conecta y endurece el form de Trabajá con Nosotros

5. Bloque D — UX del panel admin (mejoras tempranas)

Objetivo

Quick wins de UX para que el panel sea presentable a Marketing antes de iniciar las fases formales: confirmaciones de borrado, rol real en el menú lateral, estados vacíos en listados y mensajes humanos.

Commits

Hash	Descripción
d8e64e4	feat(admin): confirmación al eliminar y rol real en el menú
b6ae956	feat(admin): estado vacío en listados sin registros
31954ea	fix(admin): mensajes de borrado claros y con etiqueta correcta
66091e6	fix(admin): rótulos de medida de imagen más claros

6. Bloque E — Beneficios y aliados configurables

Objetivo

Permitir a Marketing administrar los beneficios y descuentos sin tocar código: ABM de categorías de aliados, detalle de beneficio con comercios asociados y logos, y migración del desglose de descuentos de farmacias.

Commits

Hash	Descripción
53815e7	feat(beneficios): descuentos exclusivos configurables por categoría
6cfe231	feat(admin): ABM de categorías de aliados configurable por Marketing
37bd3bc	feat(beneficios): detalle de beneficio configurable con comercios y logos
1ddd446	chore(beneficios): migra desglose de descuentos de farmacias a aliados
10e1496	chore: ignora artefactos locales de tooling (.agents/, skills-lock.json)

7. FASE 1 — Quick wins UX del admin

Objetivo

Cerrar vulnerabilidades pendientes y darle al panel funcionalidades básicas que el legacy nunca tuvo: dashboard con métricas reales, búsqueda global y perfil de usuario.

Entregables

- **Dashboard con métricas reales** por sección en admin/home.php.
- **Búsqueda global** con highlight y agrupado por tipo (admin/buscar.php).
- **Perfil de usuario** con cambio de contraseña (admin/perfil.php).
- Fix de XSS stored, leak de path absoluto y headers de seguridad (CSP, X-Frame-Options).
- Eliminación de get_magic_quotes_gpc() incompatible con PHP 8.
- Botón Cancelar deja de enviar el formulario.
- Habilitación de guion en rewrite rule para URLs agregar- y editar-.
- Protección CSRF en el borrado de los 10 listados que faltaban.

Commits

Hash	Descripción
9aa7ef9	fix(admin,ui): refuerza guards de escritura y corrige contraste de heros
40eecf8	feat(admin): escritorio con métricas reales por sección
f9f4bcc	feat(admin): búsqueda global con highlight y agrupado por tipo
3c8849e	feat(admin): perfil de usuario con cambio de contraseña
5379bbd	fix(admin): corrige XSS stored, leak de path y headers de seguridad
ffdac1c	fix(admin): elimina get_magic_quotes_gpc() incompatible con PHP 8
9c01e56	fix(admin): corrige form de alta para que Cancelar no envíe el submit
58683f2	fix(admin): habilita guion en rewrite rule para URLs con agregar-/editar-
90eea17	fix(admin): agrega protección CSRF al borrado de los 10 listados faltantes

8. FASE 2 — Productividad en listados

Objetivo

Eliminar la fricción de los listados: agregar búsqueda, paginación y exportación a CSV en todos los CRUDs sin duplicar código. Crear partials reutilizables y completar el esquema de la base.

Entregables

- **Migración 001:** crea las 8 tablas faltantes (tbl_agenda, tbl_agenda_detalle, tbl_galeria, tbl_nacionalidad, tbl_speaker, tbl_sponsor, tbl_apoyan, tbl_fotos).
- **Partial tabla-searchable** con DataTables ES, búsqueda, paginación, ordenamiento y Exportar CSV.
- **18 listados** migrados al nuevo partial (planes, convenios, aliados, blogs, médicos, sanatorios, slider, servicios, etc.).
- **Partial upload-imagen** con drop-zone, preview y validación.
- **11 formularios de upload** migrados al partial.
- Fixes: typo URI/URL, tamaño slider, comentarios de carpetas compartidas.

Commits

Hash	Descripción
878b481	feat(db): crea las 8 tablas faltantes del panel y agrega migración incremental
972abc1	fix(admin): corrige typo URI/URL, tamaño de slider y comentarios de carpetas compartidas
58f3226	feat(admin): partial reutilizable para listados con DataTables + búsqueda + CSV
f4118e0	refactor(admin): migra 18 listados al partial tabla-searchable
62a6082	refactor(admin): migra 11 formularios de upload al partial upload-imagen

9. FASE 3 — Nuevas funcionalidades

Objetivo

Sumar al panel las funcionalidades que un CMS moderno necesita: CRM de leads, biblioteca de medios, papelera de reciclaje y recuperación de contraseña por email.

Entregables

- **Biblioteca de medios** (admin/medios.php) — grid filtrable con 237+ imágenes existentes del sitio.
- **Papelera de reciclaje** (partial papelera-toggle) con soft-delete, restaurar y borrar definitivamente en 9 listados.
- **Módulo de Leads** (admin/leads.php): inbox CRM con filtros (origen, estado), edición de notas y cambio de estado (nuevo, contactado, cerrado, spam).
- **Migración 002**: persiste leads en tbl_leads desde el formulario público de contacto.
- **Recuperación de contraseña** con tokens de un solo uso, expiración y notificación por SMTP.
- **Migración 003**: tabla tbl_user_token genérica para tokens de un solo uso.
- Links de Leads y Biblioteca agregados al sidebar.

Commits

Hash	Descripción
f54b026	feat(crm): persiste leads en tbl_leads al enviar formulario de contacto
34d1963	feat(crm): admin/leads.php inbox con filtros, estados y notas
823ec40	feat(admin): biblioteca de medios (admin/medios.php) con grid + filtros + delete
827d0f5	feat(admin): papelera de reciclaje con restaurar y borrar definitivamente
d582731	feat(auth): flujo de recuperación de contraseña con tokens de un solo uso
eae806f	feat(admin): agrega links de Leads y Biblioteca de medios al sidebar

10. FASE 4 — Calidad, seguridad y autonomía

Objetivo

Cerrar el ciclo: auditoría completa de acciones, gestión de usuarios (CRUD con roles), reemplazo de `alert()` por toasts modernos y backup/restore de la base desde el propio panel.

Entregables

- **Migración 004:** tabla `tbl_audit_log` con snapshots JSON antes/después.
- **Visor de auditoría** (`admin/auditoria.php`) con filtros (usuario, acción, entidad, fecha, búsqueda libre) y exportación CSV.
- Hook `samap_audit_log` inyectado en CRUDs, login/logout y cambios de estado de leads.
- **Sistema de toasts no-bloqueantes** (`samap_flash_set/get/render`) en `funciones/seguridad.php`.
- **Reemplazo de 113 `alert()`** por `samap_flash_set` en 58 archivos.
- **Gestión de usuarios del panel:** CRUD con `bcrypt`, validación, prevención de auto-borrado y `soft-delete`.
- **Migración 005:** columnas `email`, `ultimo_acceso` y `activo` en `tbl_user`.
- **Backup/restore** desde `admin/backup.php`: dump comprimido `.sql.gz` con `mysqldump` + fallback PHP puro, restore en transacciones chicas con confirmación de dos pasos.

Commits

Hash	Descripción
876ebd8	feat(audit): tabla <code>tbl_audit_log</code> + <code>admin/auditoria.php</code>
5013b3c	feat(audit): hook <code>samap_audit_log</code> en CRUDs, auth y lead status
519229d	feat(ui): sistema de toasts no-bloqueantes (<code>samap_flash_*</code>)
21bc3b3	refactor(admin): reemplaza 113 <code>alert()</code> por <code>samap_flash_set</code> en 58 archivos
33ec540	feat(admin): gestión de usuarios del panel (CRUD)
d783569	feat(admin): backup y restore de la base de datos desde el panel

11. QA — Scripts de testing

Objetivo

Dejar reproducibles los tests E2E que los agentes de QA corrieron durante las cuatro fases para verificar el comportamiento del panel desde fuera, vía HTTP + DB.

Contenido

- 17 scripts PowerShell en scripts/test-phase1/ (login, listados, dashboard, búsqueda, delete con/sin CSRF, papelera, etc.).
- 6 scripts bash en docker/ (test-all.sh, test-listado.sh, test-slider.sh, test-delete.sh, test-usuarios.sh, lint-all.sh).
- Script de conexión a DB y restore de slider para casos puntuales.

Commit

Hash	Descripción
a630332	test: agrega scripts de testing de Fases 1-4 (PowerShell + bash)

12. Inventario final y métricas

Métricas globales

Métrica	Valor
Commits totales en el branch	49
Archivos tocados (total)	280
Líneas añadidas	+26.538
Líneas eliminadas	-4.295
Tablas MySQL	24
Migraciones incrementales	5 (001-005)
Partials reutilizables	3
Archivos nuevos en admin/	18
Archivos modificados en admin/	61
alert() restantes en código de aplicación	0
Roles definidos	3 (admin / editor / comercial)
Listados con papelera de reciclaje	9
Listados con búsqueda + paginación + CSV	18
Formularios de upload refactorizados	11
Scripts de testing automatizado	23

Partials reutilizables creados

- admin/partials/tabla-searchable.php — listados con DataTables, búsqueda, paginación y export CSV.
- admin/partials/upload-imagen.php — input de archivo con preview y validación.
- admin/partials/papelera-toggle.php — banner y toggle de vista de papelera.

Migraciones incrementales

- 001-create-missing-tables.sql — 8 tablas faltantes del esquema legacy.
- 002-create-tbl-leads.sql — persistencia de leads del formulario público.
- 003-create-tbl-user-token.sql — tokens de un solo uso para recuperación.
- 004-create-tbl-audit-log.sql — log de auditoría con snapshots JSON.
- 005-add-user-cols.sql — columnas email, ultimo_acceso, activo en tbl_user.

13. Estado actual del repositorio

Rama y working tree

El branch `feat/rediseño-web` está al día con `origin/feat/rediseño-web`. Quedan en el working tree los siguientes archivos modificados sin commitar:

- `assets/css/rediseño-base.css`
- `assets/css/rediseño-convenios.css`
- `assets/css/rediseño-home.css`
- `admin/partials/tabla-searchable.php` — fix del warning *Cannot reinitialise DataTable* (cambio del `$table_id` por defecto de `datatable1` a `samap-tabla`).

Credenciales del seed (desarrollo)

El seed incluye un único usuario administrador con hash MD5 legacy (`d0d71a1ccaa965f9c4b334d2bae558b1`). El login detecta el hash legacy y lo migra automáticamente a bcrypt en la primera autenticación exitosa.

Usuario	admin
Contraseña	admin123
URL local	<code>http://localhost:8081/admin/</code>

Importante: rotar esta contraseña antes de cualquier despliegue a producción — está expuesta en el seed público y en los scripts de tests.

Próximos pasos sugeridos

- Borrar los bloques `#datatable1/2/3` en `admin/app/js/app.js:148-200` (código muerto del template original).
- Encriptar a nivel de columna las PII de leads (teléfono/email) según Ley 6534/20.
- Sumar tests automatizados para los flujos de auditoría y backup/restore.
- Documentar el playbook de deploy a la VM GCP (PM2 + Nginx + certbot) en `docs/deploy.md`.

Fin del informe — SAMAP · Rediseño del sitio público y panel administrativo · branch `feat/rediseño-web`.